

# PrimusCredence

---

Provable Security

---

[primuscredence.com](https://primuscredence.com)

UAE

# Dr. Raghavendra Ramesh

Founder & CEO, PrimusCredence

22+ YEARS OF EXPERIENCE IN PROVABLE SECURITY

## **PhD, IISc Bangalore**

Model checking for information-flow security

## **Oracle Labs · 2014–2019**

Java vulnerability detection

## **ConsenSys R&D · 2019–2021**

Cross-chain protocols, consensus verification

## **Supra · VP of R&D · 2021–ongoing**

BFT design & FV, bridges, DeFi & Crypto

### **TECHNIQUES**

Static analysis, theorem proving,  
model checking

### **TOOLS**

Dafny, TLA+, IVy, Lean, Isabelle

# Where the Risk Actually Lives

*The cloud base is proven. The app above it — and the seams between — are not.*

## Third-party plugins & extensions

Run inside the app — and inherit its privilege

## APPLICATION

Its own roles, API tokens and public users — the authorisation logic and configuration in its database and admin panel

**OWASP #1 Broken Access Control · #2 Misconfiguration — in 100% of apps**

## THE APP ↔ CLOUD & LIBRARY SEAM

- Access control via APIs
- SDK & library usage
- PQC app↔cloud binding

## CLOUD & INFRASTRUCTURE

VMs · containers · databases · queues · object storage · IAM · network

**Access control, network & PQC transport — proven: Zelkova, Tiros, ML-KEM**

## UNPROVEN TODAY

### Where the breaches are

The app's own access control, its plugins, and the API, library and PQC seams beneath it.

→ **This is what we prove.**

## PROVEN BASE

Cloud IAM, network & PQC transport — already formally verified.

# OWASP 2025 — Access Control & Misconfiguration

*The two categories at the top are found in 100% of apps tested.*



## Broken Access Control

#1 — unchanged

40 CWEs · 1.84M occurrences · 32,654 CVEs  
SSRF now folded in — easy to exploit, widespread.



## Security Misconfiguration

#2 — up from #5

16 CWEs · 719,084 occurrences  
Again, 100% of tested apps carried a form of it.

### BROKEN ACCESS CONTROL IN THE WILD

|              |      |                                                                        |
|--------------|------|------------------------------------------------------------------------|
| Capital One  | 106M | WAF SSRF → over-privileged role; a tipster found it, ~4 months in      |
| Optus        | 9.5M | access-control bug on a dormant, internet-facing API — latent ~4 years |
| T-Mobile     | 37M  | API data retrieval without authorization — ~6 weeks to notice          |
| Dell         | 49M  | auto-approved fake partner, then service-tag enumeration               |
| Trello       | 15M  | unauthenticated email lookup through rotating proxies                  |
| Twilio Authy | 33M  | unauthenticated endpoint enumerated for phone numbers                  |

Every one was a well-formed, authenticated request a monitor read as normal.

# Apps Misuse the APIs They Run On

*Cloud and app APIs are protocols, not calls — misuse still compiles.*

## THE PATTERN

- An object fetched by request ID with no ownership check — BOLA / IDOR
- A credential written to a log; pagination left undrained
- Authorisation in middleware a scanner can't see

## THE TREND IS NOT REVERSING

- +29% IDOR reports year on year (HackerOne 2025)
- +36% access-control criticals — now #1 (Bugcrowd 2025)
- ~95% of API attacks carry a valid token — authentic, not authorised

**\$4.4M**

average cost of a data breach  
(IBM 2025)

**241 days**

mean time to identify and  
contain (IBM 2025)

**258 / day**

API attacks per enterprise —  
2× 2024 (Akamai 2025)

**A correct policy invoked through a misused SDK still leaks.**

# The Base Went Post-Quantum. Are the Apps Ready?

*The internet and cloud layer are shifting to hybrid PQC — and it is proven.*

## ALREADY SHIFTING, ALREADY PROVEN

- NIST FIPS 203 / 204 / 205 (Aug 2024)
- Hybrid ML-KEM default in browsers
- Live at Cloudflare, AWS, Google, Apple
- ML-KEM itself machine-checked (2024)

## THE APP ON TOP IS NOT

- No identity binding → impersonation
- Downgrade to legacy → decrypt later
- KEM key reuse → forward secrecy lost
- Token not channel-bound → replayed

## LONG-SECRET VERTICALS BITE HARDEST

Gov ID (10+ yr) · PKI · healthcare · defence (25–50 yr).  
A mis-bound 10-year credential is a decade-long liability.

**A proof at the transport layer says nothing about the app on top of it.**

# AI Industrialises the Attacker

*A sampling defence cannot answer an enumerating attack.*

**4.5×**

revenue of AI-assisted scam operations versus non-AI equivalents

**\$3.52**

average compute cost per LLM-agent exploit attempt on a real CVE

**87%**

of a 15-CVE sample exploited from the public description alone

## TRADITIONAL PEN TEST

$10^2$ – $10^3$  paths, human-selected  
2–4 week window, then closed  
High marginal cost per path  
“We found no way in”

## AI-DRIVEN ADVERSARY

$10^5$ – $10^7$  paths, machine-enumerated  
Continuous, no window  
Near-zero marginal cost  
Approaching exhaustive

**Proof is the one capability that answers exhaustive search in kind.**

# Segmentation Is Asserted, Not Proven

*Once inside, lateral movement is the phase that turns an incident into a breach.*

**29 min**

average breakout to the first lateral move (2025)

**27 sec**

the fastest breakout ever observed

**82%**

of intrusions were malware-free — valid access, not code

## WHY PROBING CAN'T ANSWER IT

- Tests only the paths you thought of
- Can't tell blocked from about-to-change
- East-west is claimed more than shown

## REACHABILITY IS A CONFIG PROPERTY

- Routes, SGs, NACLs, firewall rules
- Decided statically — no scanning window
- Precedent: AWS Tiros · Batfish

On an OT network probing is forbidden — the IT/OT boundary must be proven, not tested.

# Why Today's Security Stack Isn't Enough

*The collective wisdom of years of breaches — yet each only samples.*

SAST / DAST / IAST

SCA / supply chain

ASPM

WAF / API security

CSPM · CIEM · CNAPP

Pen test & red team

SOC · EDR · SIEM

Policy-as-code

- **SAST** Knows code patterns, not intent. A check present but wrong still passes.
- **DAST** Only crawled endpoints and seeded data; even multi-persona only samples.
- **IAST / RASP** Same-code-path BOLA is invisible — was the call even permitted?
- **SCA / ASPM** Known CVEs and risk diffs; never whether a grant is actually correct.
- **CNAPP / CSPM** Stops at the cloud IAM role; never reads the app's own roles.
- **WAF / API sec** A permitted request and a legitimate one look identical on the wire.

They all share one gap: no statement of what is allowed, decided over every request.

**Keep every one of them — and add the layer that closes that gap.**

# Proof — Now Feasible

*Formal verification used to take expert teams years. AI brings it into range.*

## THEN

- Expert teams, bespoke specs, years
- Confined to avionics, silicon, protocols
- “End users won’t write a spec”

## NOW — AI-ASSISTED

- AI assists modelling & proof search
- Expert owns & ratifies the spec
- AWS runs ~1B SMT queries a day

**What we add** A preventive control with evidence behind it, beside your testing and SOC.  
**We add to your stack; we don’t replace it. Proof alone isn’t enough.**

## WHAT STAYS WITH YOU — ALL OF IT NEEDED

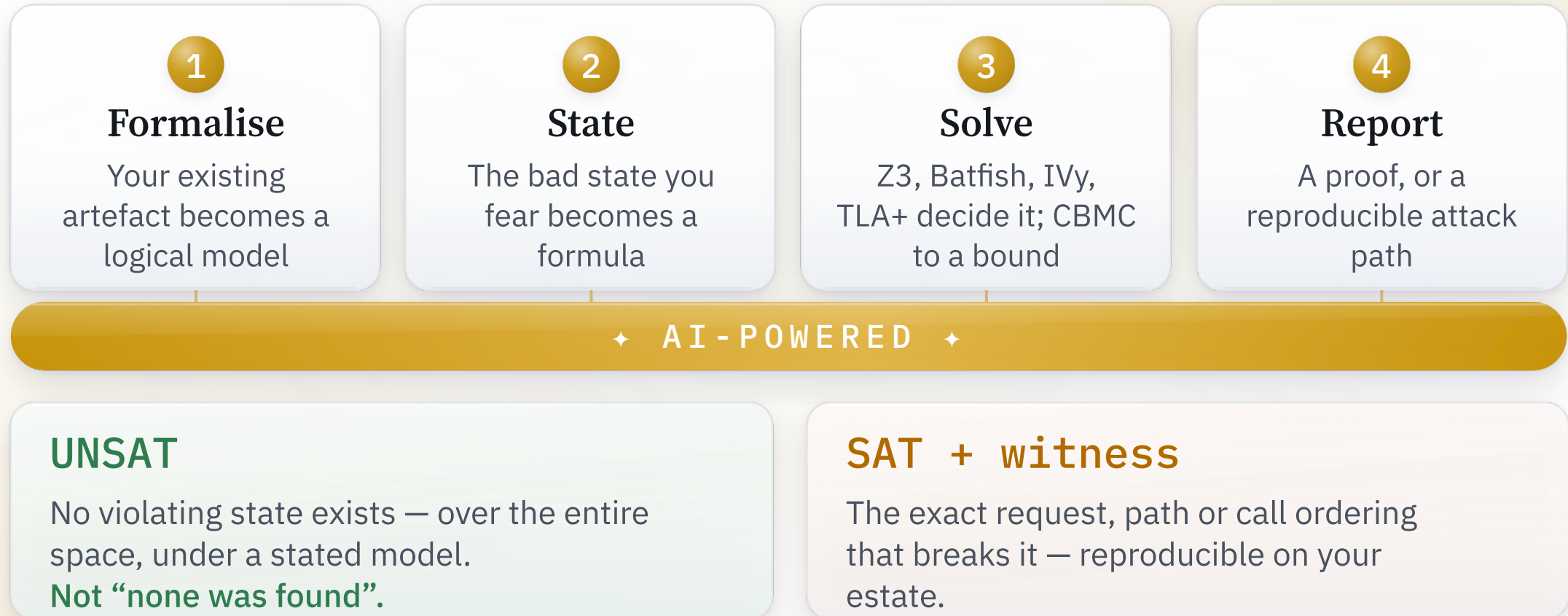
Configuration drift, shadow assets and anything outside the model

Insider misuse, and valid credentials used exactly as intended

Detection, response and the rest of the programme you already run

# Automated Reasoning

*Proof establishes that bad things cannot happen.*



Not every property is decidable, and a proof holds only for the property and model stated.

Industrial practice: AWS · Microsoft · Meta · Airbus.

# Solutions

## 1 App entitlement proofs

Who can reach what?

## 2 Network segmentation

Any path across zones?

## 3 App & API conformance

SDKs used correctly?

## 4 Post-quantum migration

Bound on a PQC base?

## 5 Agentic guardrail verification

What an agent may do?

# 1. Application Access-Policy & Entitlement Verification

*What can each app role, API token and public user do inside the app — and can any of them reach what they should not?*

## THE PROBLEM

An app's authorisation lives in its own database and admin panel — which role reads which type, what the Public role exposes. No SAST, CSPM or CNAPP reads it; DAST only samples.

*Portable: it reads the app's own config, so it holds on-prem, not only in cloud.*

PRECEDENT Cedar + SymCC → Cedar Analysis  
BUYERS Platform & AppSec teams · ISVs

## WHAT WE BUILD

- The app's roles, API tokens and public users, into Cedar
- SymCC decides over all requests — BOLA, BFLA, BOPLA
- CheckNoNewAccess gates every role change in CI

## OUTPUT

Proof that no role, token or public user reaches what it must not — over all requests — or the exact request that breaks it.

## 2. Network Reachability & Segmentation Proofs

*Does any path exist from an untrusted zone to this subnet — and does east-west segmentation actually hold?*

### THE PROBLEM

Probing tests the paths you thought of, when you ran it. Reachability is a property of the configuration — routes, security groups, firewall rules — not of the packets you send.

*No scanning window, no production traffic — it re-runs on every change.*

**PRECEDENT** AWS Tiros → VPC Reachability Analyzer

**BUYERS** Regulated finance · OT & critical infra · sovereign cloud

### WHAT WE BUILD

- Hybrid and on-prem estate modelled with Batfish
- Soufflé and Z3 over the cloud topology, statically
- Microsegmentation checked against the declared policy

### OUTPUT

A proof that no path exists — or the path, hop by hop, with the rule that permits it and the owner of that rule.

# 3. Application and API-Usage Conformance

*Does our own code use the APIs it is built on — cloud, credential and crypto SDKs, and its own data-access calls — the way their contracts*

## THE PROBLEM

Cloud and app APIs are protocols, not calls. Undrained pagination, a logged credential, an object fetched by request ID without an ownership check — all compile and pass review. Same risk

*A correct policy invoked through a misused SDK still leaks. Bounded by the library.*

PRECEDENT    AWS RAPID → CodeGuru · 76% accepted  
BUYERS        Platform and AppSec teams · ISVs

## WHAT WE BUILD

- Object-ownership (BOLA/IDOR) and auth-routing patterns
- A conformance gate for library publishers
- PR-gate CI on Soot, CodeQL and Infer

## OUTPUT

The call site, the taint trace, the pattern violated and the corrected call sequence — plus which patterns were checked.

# 4. Post-Quantum Cryptography Migration

*On an already quantum-safe cloud, does the app's integration still authenticate the right party in every session?*

## THE PROBLEM

The cloud's PQC transport can be formally proven and the app on top still relayed or downgraded. Hybrid migration adds identity-binding and combiner failures that code review ships past.

*Verified app crypto on an already-verified cloud — proof end to end.*

**PRECEDENT** PQ-SSH counterexample, then proved (2024)

**BUYERS** Gov ID · PKI · banks · healthcare · defence

## WHAT WE BUILD

- Discovery and a versioned CBOM, gaps listed
- The app-to-cloud integration protocol, transport proof discharged
- Identity, channel and downgrade binding, over all sessions

## OUTPUT

The CBOM and a sequenced plan; then a proof the app's integration preserves authentication and secrecy on the verified base — or the relay that breaks it.

# AI Agents Multiply Faster Than the Rules

*An agent is a non-human identity with delegated privilege and a writable channel.*

## THE RULES ARE ARRIVING

- EU AI Act — Art. 15 robustness & security
- ISO/IEC 42001 — AI management system
- ISO/IEC 24029-2 — formal methods for AI
- DIFC Reg 10 · Dubai AI Seal · SDAIA

*The assurance market does not exist yet — anywhere. You would be early, not late.*

## THE CHALLENGE — GUARDRAILS ESCAPE

A guard model judging a model is detective, not preventive. The question is not “how often does it fail?” but “can it do this at all?”

- 
- 5 What an agent may do**  
tool calls, arguments, data access

**Our AI-agentic guardrail solution proves the mediation layer, not the model →**

# 5. Agentic AI Guardrail Verification

*Not “how often does the agent fail?” but “can it do this at all?”*

## THE PROBLEM

An agent is a non-human identity with delegated privilege and an instruction channel the adversary can write to. A guard model judging a model is detective, not preventive.

*Provable: no rows outside the caller's ACL.*  
*Not provable: no PII ever reaches the user.*

PRECEDENT    Bedrock Automated Reasoning  
BUYERS        Banks · sovereign AI · OT · healthcare

## WHAT WE BUILD

- Tool-call constraints over identity and arguments
- Data-access boundaries in the Solution 1 logic
- Composition safety across call sequences

## OUTPUT

A result about the mediation layer, not the model: nothing permitted escapes the envelope, and no path bypasses it.

# Our Approach

*We partner with cybersecurity solutions providers, adding provable assurance.*

HOW WE PARTNER – THROUGH THE PROVIDERS

—

Provable control effectiveness inside their bids.

—

They keep the client relationship and the contract.

—

We don't certify — a channel, not a rival.

WHOM WE REACH THROUGH THEM – THE GCC CLIENT BASE

Government & sovereign

UAE Digital Govt

Smart Dubai

Abu Dhabi Govt

Aviation & CNI

dans · air navigation

DEWA

Regional utilities

Energy, oil & gas

ADNOC

Aramco

OT operators

Banking & finance

Regional banks

Sovereign wealth funds

FinTechs

Telecom & cloud

e& · Etisalat

Core42 · G42

STC Cloud

# Why the Provider's Clients Will Ask

*Four things happened at once in the GCC — and their clients feel all four.*

**Mandatory replaced voluntary**

UAE cyber-resilience obligations now carry penalties of AED 100k–3m.

**Assurance shifted to evidence**

Regulators increasingly ask for demonstrable control effectiveness, not attestation.

**AI rules arrived before AI assurance**

Risk-tiered obligations demand evidence the market cannot yet produce.

**Sovereignty is a reachability question**

Localisation asks whether regulated data can leave — our reachability proofs settle it.

| WHERE A FINDING ALSO LANDS |         |                |       |              |       |
|----------------------------|---------|----------------|-------|--------------|-------|
| DESC ISR                   | 1 2 3   | NESA / UAE IAS | 2     | UAE PDPL     | 2 3 5 |
| SAMA CSF                   | 1 2 3 5 | NCA ECC        | 1 2 3 | UAE AI Act   | 5     |
| ISO 27001                  | 1 2 3 4 | ISO 42001      | 5     | NIST CSF 2.0 | 1–5   |

*Regulation routes the finding to a second reader. It is not the reason to commission it.*

# What a Provider Can Resell

*We do not certify — so an audit firm or an MSSP is a channel, not a rival.*

Scanning · posture reporting · monitoring



**Provable control effectiveness**

## THE COMMERCIAL MOVE

- Specialist capability inside bids you already win
- You keep the client relationship and the contract

## WHY IT DEPLOYS EASILY

- Read-only access, no agent on any host
- No scanning window, no production traffic

Read-only and agentless, so it clears change advisory in one pass.

We produce the technical evidence. Your assessor keeps the opinion.

# One Result, Three Registers

## First line

Engineering and security operations

The property, its model and assumptions, and either the proof or a reproducible attack path.

## Second line

Risk

Likelihood moved off a qualitative guess, with residual risk and the model's limits stated.

## Third line

Internal audit and compliance

A clause-mapped control assertion: objective, status, owner and re-verification date.

✓ Design → operating effectiveness · attaches to your GRC records · assessors probe less

*The first register is the product. The second and third make it worth more than it cost.*

# Take Away

## Mathematical rigour to security — proof alongside testing, across apps and AI.

### The shift

Attack path discovery is automated, parallel and cheap. A defence that only samples cannot answer one that enumerates.

### The addition

We do not replace testing, monitoring or the SOC. We make one class of controls machine checkable.

### The honesty

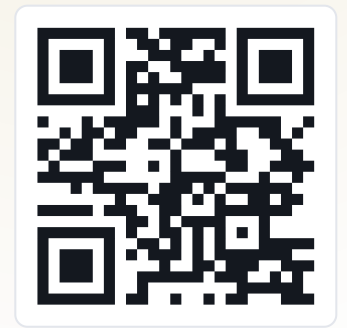
A proof is relative to a model and a specification — both stated. We produce the evidence; we do not certify.

#### START HERE — MICRO ASSESSMENT OF SOLUTION 1

One narrow, high-risk slice. Read-only access, no agent deployed, weeks not months — and a counter-example on your own systems, or a proof.

# Thank You

---



[primuscredence.com](https://primuscredence.com)

**Dr. Raghavendra Ramesh**

Founder & CEO, PrimusCredence  
PhD, IISc Bangalore

[raghavendra@primuscredence.com](mailto:raghavendra@primuscredence.com)

+971 58 189 2803  
UAE

**Provable Security for Apps & AI Agents**